

Technology Services

Patch Management Guidelines

1. Purpose

This document describes requirements for identifying software security vulnerabilities that could be exploited to compromise SCU (Southern Cross University) Technology Services (TS) applications, systems and service components and their remediation by applying updates (referred to hereafter as patches). These guidelines apply to all forms of software including:

- operating systems, drivers and firmware running on computing devices
- web and client-server applications
- mobile and desktop applications

It also applies to vulnerabilities in computing hardware addressed with software patches.

2. Risk Response Approach

SCU has a **low** appetite for any disruptions to its critical IT/operating systems, assets or infrastructure which may result in a prolonged University and operational disruption. By default, SCU acknowledges the risk associated with the use of its software. Software may contain vulnerabilities that may not yet be discovered in what is known as a zero-day attack. When a new vulnerability becomes publicly known, the risk escalates as attackers are more likely to create exploits targeting the susceptible software.

2.1 Risk Responses

The methods of risk response capable of eliminating vulnerabilities without compromising functionality involve installing patches or updates, or upgrading the software to a version devoid of vulnerabilities. The prompt application of patches, updates, or upgrades to address vulnerable software may not always be feasible.

Patching is one of several ways in responding to software vulnerabilities. In line with SCUs Risk Management Framework the response to vulnerabilities should consider the following:

1. **Accept:** Accept the risk associated with vulnerable software, either by depending on existing security controls to prevent the exploitation of vulnerabilities or by determining that the potential impact is sufficiently low to warrant no further action.
2. **Mitigate:** Reduce the risk by addressing vulnerabilities, such as applying patches to the susceptible software, deactivating vulnerable features, or upgrading to a newer software version devoid of vulnerabilities. Additionally, deploy extra security measures to diminish

the exploitation of vulnerabilities, such as using firewalls and network segmentation to isolate vulnerable assets and thereby decrease the attack surface.

3. **Transfer:** Decrease the risk by sharing some of the consequences with another party. This can be achieved through actions like transitioning from traditional software installations to the usage of software-as-a-service (SaaS), where the SaaS vendor or managed service provider handles the patching.
4. **Prevent:** Ensure that the risk is averted by eliminating the attack surface. This can involve uninstalling the vulnerable software, decommissioning assets with vulnerabilities, or deactivating computing capabilities in assets that can operate without them.

2.2 Vulnerability Management Life Cycle

The following outlines the vulnerability management lifecycle shall apply to all SCU risk response approaches.

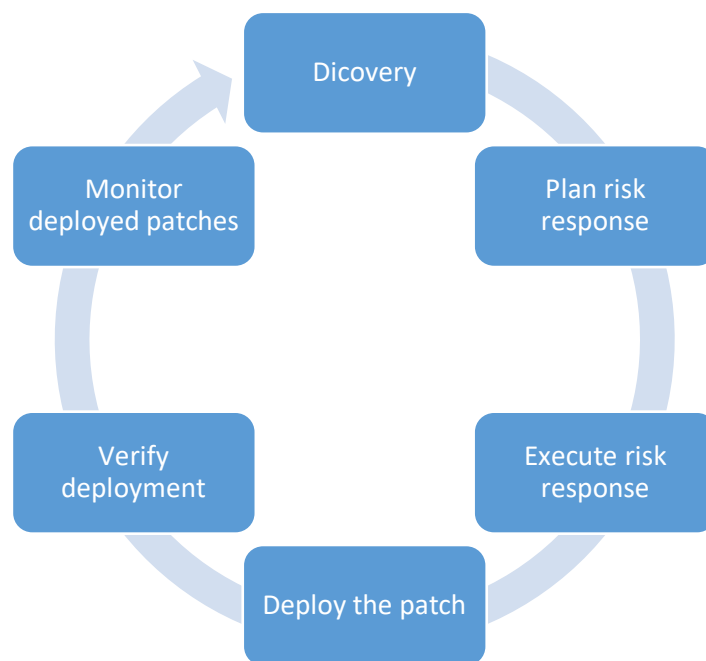


Figure1: Vulnerability Management Lifecycle

1. **Discovery** – Monitoring the application packages and libraries for latest patch levels and advisories on vulnerabilities.
2. **Plan risk response** – Assess vulnerabilities and determining the most appropriate risk response to implement.
3. **Execute risk response** – Validate patches and/or security safeguards and coordinate deployment plans and patches based to risk/vulnerability ratings.
4. **Deploy the patch** – distribute patches, deploy additional controls and change asset configuration states (i.e. device resets) where appropriate.
5. **Verify risk response** – ensure has completed successfully without any ill effects to the organisation. Ensure any deprecated versions or patch artifacts are removed.
6. **Monitor deployed patches** – monitoring using automation for any ill effects and no exploits occur.

3. Roles, Responsibilities and Accountabilities

3.1 Cyber Security team

The Cyber Security team are responsible for monitoring high-risk vulnerabilities and reviewing patch exceptions.

3.2 Technical owners

Technical owners are responsible for following these guidelines for TS service components they are responsible for, including implementing regular and emergency patching and ensuring adequate vulnerability monitoring and sufficient systems and processes to permit the timely application of patches are in place.

4. Process and Key Controls

4.1 Regular Patching of TS Service Components

To reduce the window in which systems may have known software vulnerabilities, and to maintain systems in a serviceable state, regular patching schedules shall be implemented by technical owners in line with defined Frequency of regular patching schedules (*Table 1*).

Patches shall be deployed as close possible to when they are released by the vendor to mitigate the risk of exploitation, whilst allowing sufficient time for testing to manage the risk of negative operational impacts.

The frequency of patching also needs to consider the time and resources required to deploy patches.

Technical owners are responsible for ensuring that sufficient systems and processes are in place to permit the timely application of patches as per this standard's requirements.

Vendors may release patches regularly referred to here as the vendor patch frequency. In these cases, patches shall be deployed within 10 working days of the patch being released.

Some software vendors provide an automated patching service that applies patches as they are released to ensure security vulnerabilities are resolved as quickly as possible. Automated patching should be enabled where the risk of exploitation is greater than the risk of negative operational impacts caused by a faulty Patch.

4.2 Emergency Patching

Emergency patches need to be performed outside the regular patching cycle to resolve high risk (P1, P2 and P3) vulnerabilities within the timeframes defined in *Table 5*. Emergency patching shall be treated similarly to an IT incident and logged accordingly.

4.3 Patching during change freezes

Change freeze periods are typically designated timeframes during which alterations are minimised, primarily to safeguard SCU operations during pivotal moments. Despite this, emergency changes and patching activities during these freeze periods through an exemption process may be required.

The identification of fresh vulnerabilities and disturbances caused by malicious actors can transpire at any moment. Consequently, the technical owner shall ensure the ongoing resolution of vulnerabilities during change freeze periods, particularly within a 48-hour timeframe for internet-facing infrastructure. Critical vulnerabilities, impacting essential applications or operating systems, shall also be promptly addressed using patches or recommended mitigations from vendors during these freeze periods. In certain instances, non-traditional vendor mitigations may precede or accompany a disruptive patch. If initial vendor mitigations are applied, subsequent patching should follow.

5. Key Requirements

5.1 Patching Frequency

The following table defines requirements for the frequency of patching for different IT service components:

Service Element	Patching Requirement
Server Operating System (OS)	Patches applied at the vendor patch frequency or at least quarterly if the vendor does not have a regular patch cycle
Server firmware	Emergency patching only
Workstation OS	Patches applied at the vendor patch frequency or at least quarterly if the vendor does not have a regular patch cycle
Workstation commonly targeted desktop application (See Appendix 7.2)	Automated patching enabled where available. Otherwise, patches applied at the vendor patch frequency or at least quarterly if the vendor does not have a regular patch cycle
Workstation other desktop applications	Automated patching enabled where feasible, or emergency patching only
Workstation Firmware	Emergency patching only
Mobile OS	Automated patching enabled
Mobile applications	Automated patching enabled
Internet accessible network equipment	Quarterly
Other network equipment	Annually
Firewalls and security appliances	Quarterly
Storage equipment	Every six months
Tier 0, tier 1 and confidentiality tier 2 (SENSITIVE) web/client-server applications	Quarterly
Other web/client-server applications	Every six months
AV, multi-function devices and IoT equipment	Emergency patching only

Table: Frequency of regular patching schedules

5.2 Monitoring of Vulnerability Alerts

Processes should be in place to ensure high-risk vulnerability alerts are reliably received by staff responsible for deploying patches as soon as possible after they are released.

Technical owners are responsible for ensuring adequate monitoring is in place for TS service components they are responsible for. The Cyber Security team provides additional monitoring of high-risk vulnerabilities to ensure they are acted upon in time.

Technical owners shall ensure that automated vulnerability detection is implemented for TS service elements under their control. Monitoring dashboards or reports should be reviewed frequently enough to ensure high risk vulnerabilities can be responded to rapidly. If automated vulnerability detection is not able to be implemented, alternative processes should be used such as subscribing to vendor vulnerability alert services or regularly monitoring vulnerability alert pages published by vendors.

The Cyber Security team will distribute high-risk vulnerability alerts received from subscription services and other sources to impacted technical owners and monitor threat intelligence regarding which vulnerabilities are being actively exploited. Technical owners shall provide enough information to the Cyber Security team to enable efficient determination of whether TS service elements under their management are impacted by a particular vulnerability.

5.3 Prioritisation Treatment of Vulnerabilities

Due to the high volume of software vulnerabilities, it is essential to optimise risk mitigation by prioritising remediation of higher risk vulnerabilities.

If automated vulnerability detection is being used, then the default patch priority is based on the vulnerability severity rating reported by the vulnerability monitoring tool. If the tool uses a different set of ratings, a suitable mapping must be agreed with the Senior Manager of the Cyber Security Operations Team. Otherwise, the default priority is based on the Common Vulnerabilities Severity Score (CVSS), context, and whether the vulnerability is known to be actively exploited as defined in *Table 2* Patch severity-based priority ratings

Software Vulnerability Severity	Priority
Critical	1
High	2
Medium	3
Low	4
Informational	5

Table 2: Patch severity-based priority ratings

Not activity exploited

CVSS	Internet accessible service/device	Network accessible service/device or commonly targeted desktop application	Other
9.0-10	1	3	4
7.0-8.9	2	4	5
4.0.6.9	3	5	5
0-3.9	5	5	5

Table 3: CVSS-based priority ratings exploited

Known to be exploited

CVSS	Internet accessible service/device	Network accessible service/device or commonly targeted desktop application	Other
9.0-10	1	2	3
7.0-8.9	2	3	4
4.0.6.9	3	4	5
0-3.9	4	5	5

Table 4: CVSS-based priority ratings not exploited

5.4 Maximum Deployment Times

The maximum deployment times for each priority rating shall be considered based on the risk and priority to patch (Table 5). Deployment refers to the process of installing and activating a patched version of the software (including required reboots) to remediate the vulnerability or implementing a configuration change or compensating control to mitigate the risk of exploitation. The preferred approach is to remediate vulnerabilities within the maximum deployment time, however if this is not possible mitigating controls should be put into place instead within this period.

Where a pre-existing mitigation exists, or a mitigation is put into place, or the vulnerability is erroneously reported by the vulnerability management tool (a false positive), a patching exemption may be requested. Patching exemptions may be approved by the Senior Manager, Cyber Security team and shall be recorded (in the vulnerability management tool itself where feasible, or otherwise in a separate register) along with the date, reason for the exemption and supporting information.

Category	Maximum time to deploy since vulnerability detection
Priority 1	48 Hours
Priority 2	10 Working Days
Priority 3	20 working days
Priority 4	In line with standard patching cycle
Priority 5	In line with standard patching cycle

Table 5 Maximum patch times

5.5 Forced reboots of staff devices

In cases where a staff device must be rebooted to activate patched software, staff should receive adequate warnings to perform the reboot themselves, after which a forced reboot is applied within a timeframe required to meet the maximum deployment time objective.

5.6 Change Management

Deployment of patches is subject to the Change Management Procedure which ensures that operational risk and stakeholder engagement is managed appropriately. Regular patching shall be scheduled to be performed outside TS change freeze periods, however P1 and P2 emergency patching should still be performed.

5.7 Non-Compliance

Systems that meet these guidelines pose a significant risk to SCU may be quarantined or have other mitigating controls enforced until the patches are applied or an exception approved.

5.8 Exceptions

These guidelines recognise that certain situations may warrant exceptions. Exceptions can be authorised under the following circumstances:

1. When immediate patch deployment has the potential to disrupt critical business operations, exceptions may be considered. Such exceptions require approval from the Senior Manager, Cyber Security.
2. In cases where legacy systems or unsupported software necessitate specific patches, applying these updates might lead to system instability.
3. When adherence to these guidelines contradict regulatory requirements or standards, users can formally request exceptions, which the Senior Manager, Cyber Security will evaluate and, if deemed appropriate, approve.
4. Exceptions may be applicable for third-party software or services where SCU has limited control over patch deployment. To request such exceptions, justification and documentation shall be provided to the Senior Manager, Cyber Security for approval.

6. Related Documents and Information

1. [ASCS - Patching Applications and Operating Systems](#)
2. [Common Vulnerability Scoring System](#)
3. [National Vulnerability Database](#)
4. [NIST SP 800-40 Rev. 4 - Guide to Enterprise Patch Management Planning](#)
5. [SCU Risk Management Framework](#)
6. Vendor websites/notification lists as defined by Technical owner

7. Document control

These guidelines shall be subject to periodic review to ensure currency and relevancy.

Document owner:		Senior Manager, Cyber Security		
Document approver:		Chief Information Officer		
Classification:		Sensitive		
Compliance				
Essential 8		ML3-PA-01, ML3-PA-01		
ISM		Principle: PROTECT ISM-1143; ISM-0298;		
NIST		800-40R4 Enterprise Patch Management Planning		
Revision				
Version	Approved by	Reason for Change	Approval date	Review due
V1	CIO	Initial	8 Dec 2023	8 Nov 2025

Appendix 1 - Definitions

Term	Definition
CVE Number	Common Vulnerabilities Exposure identifier for a particular software vulnerability. See https://www.cve.org/ for a list of CVE records.
CVSS	Common Vulnerabilities Severity Score that rates the threat level of a software vulnerability. See https://nvd.nist.gov/vuln-metrics/cvss for more information.
Driver	Auxiliary software for integrating peripherals with the operating system of a computing device.
Firmware	The permanent software programmed into read-only memory on a computing device, typically for performing low-level bootstrap functions
Operating system (OS)	The low-level software that supports a computing device's basic functions, such as scheduling tasks and controlling peripherals
Patch	A software update that resolves a specific security vulnerability
Software vulnerability	A software vulnerability can be exploited by a malicious party to provide unauthorised access to features or data, modify the functioning of the software, or to compromise the platform or infrastructure hosting the software.

Appendix 2 - Commonly Targeted Desktop Applications

Type	Examples
Web Browser	Microsoft Internet Explorer, Microsoft Edge, Google Chrome, Mozilla Firefox, Apple Safari
PDF Viewer	Adobe Acrobat
Productivity	Microsoft Office
Remote Tools	Splashtop